

Lecture 25 : Miscellaneous Attacks

Introduction

In today's interconnected digital landscape, the security of network communications is paramount. Users often assume their online interactions are private and direct, but this is not always the case. This lecture delves into a critical cybersecurity threat known as the Man-in-the-Middle (MITM) attack, a deceptive technique where an attacker secretly intercepts and relays communications between two parties who believe they are communicating directly with each other. This active form of attack allows the malicious actor to eavesdrop, alter, or even inject false information into the conversation, compromising data integrity and confidentiality.

We will specifically explore how MITM attacks can be executed using a combination of Address Resolution Protocol (ARP) poisoning and network sniffing. ARP poisoning manipulates the fundamental mechanism by which devices on a local network discover each other, redirecting traffic through the attacker's machine. Once traffic is rerouted, sniffing tools are employed to capture and analyze the data packets, potentially revealing sensitive information like login credentials. Understanding these techniques is crucial for both identifying vulnerabilities and developing robust defense strategies in network security.

Core Concepts

Term	Definition	Significance
Address Resolution Protocol (ARP)	A stateless protocol used to resolve IP addresses to physical MAC addresses on a local network.	Essential for devices to communicate on a local network by mapping logical IP addresses to hardware MAC addresses.
ARP Poisoning / ARP Spoofing	An attack where malicious ARP packets are sent to associate the attacker's MAC address with the IP address of another device (e.g., gateway or victim).	Redirects network traffic through the attacker's machine, enabling Man-in-the-Middle attacks and data interception.
	An active attack where an attacker secretly relays and	Allows an attacker to control communication, capture

Term	Definition	Significance
Man-in-the-Middle (MITM) Attack	possibly alters the communication between two parties who believe they are directly communicating.	data packets, and potentially impersonate either party without their knowledge.
Sniffing	The process of monitoring and capturing all data packets passing through a given network segment using specialized tools.	Enables attackers to observe network traffic, identify patterns, and extract sensitive information like passwords or confidential data.
Promiscuous Mode	A network interface card (NIC) operating mode that allows it to receive all traffic on the network, even if it is not addressed to that specific NIC.	Crucial for sniffing tools to capture all network traffic, as by default, NICs ignore packets not addressed to them.
Passive Sniffing	Monitoring network traffic without altering it, typically effective on older hub-based networks where traffic is broadcast to all ports.	Limited effectiveness in modern switch-based networks, as switches direct traffic only to the intended recipient.
Active Sniffing	Monitoring and potentially altering network traffic, used to overcome the limitations of switches by injecting packets (e.g., ARP packets).	Necessary for sniffing in modern switch-based networks, often involving techniques like ARP poisoning or MAC flooding.
Content Addressable Memory (CAM) Table	A table within a network switch that stores MAC addresses and their corresponding ports, used for efficient traffic forwarding.	Can be exploited in active sniffing (e.g., MAC flooding) to overload the switch, forcing it into a forwarding mode where all traffic is broadcast.
Port Forwarding	A network configuration that redirects communication requests from one address and	Essential for an attacker's machine to act as a relay in an MITM attack, ensuring

Term	Definition	Significance
	port number combination to another.	that redirected traffic continues to its intended destination.

Detailed Analysis

1. Understanding ARP and ARP Poisoning

The Address Resolution Protocol (ARP) is a fundamental, stateless protocol used in local area networks to map IP addresses to physical MAC addresses. When a machine needs to communicate with another device on the same network, it first checks its local ARP table. If the MAC address for the target IP is not found, an ARP request is broadcast across the network. The machine with the matching IP address responds with its MAC address, allowing the requesting machine to update its ARP table and initiate communication.

ARP poisoning, also known as ARP spoofing, exploits this stateless nature of ARP. An attacker sends forged ARP messages onto the local area network. These messages associate the attacker's MAC address with the IP address of a legitimate network device, such as the default gateway or another host. By doing so, the attacker can trick other devices into sending their traffic to the attacker's machine instead of the intended destination. This technique can also involve constructing a large number of forced ARP requests and replies to overload a switch, potentially forcing it into a forwarding mode where it broadcasts all traffic, making it easier for the attacker to sniff packets. The core idea is to flood a target computer's ARP cache with incorrect entries, effectively "poisoning" its understanding of network addresses.

2. Man-in-the-Middle Attack Mechanics

ARP poisoning is a key enabler for a Man-in-the-Middle (MITM) attack. In an MITM scenario, the attacker positions their machine between two communicating parties, typically a victim and a server (or gateway). The victims believe they are communicating directly with each other, but in reality, all traffic flows through the attacker's machine. The attacker can then control, monitor, and potentially alter the communication. This implies an active attack where the attacker establishes a connection with both the victim and the intended destination, relaying messages between them while capturing all data packets. Protocols like SSL (Secure Sockets Layer) are designed to prevent such attacks by encrypting data, making it unreadable even if intercepted.

3. Practical Demonstration Setup

To illustrate an MITM attack, a typical setup involves three machines with specific IP addresses:

- * **Attacker Machine:** 10.35.1.198 (e.g., a Kali Linux machine)
- * **Victim Machine:** 10.35.1.199 (the target whose traffic will be intercepted)
- * **Default Gateway:** 10.35.1.2 (the router or access point for the network)

The goal is to place the attacker machine logically between the victim and the default gateway, so all traffic from the victim to the internet (via the gateway) and vice-versa passes through the attacker.

4. Enabling Port Forwarding

Before initiating ARP poisoning, the attacker machine must be configured to forward IP packets. This ensures that when traffic is redirected to the attacker, it doesn't simply stop there but continues to its intended destination, maintaining network connectivity and preventing suspicion.

To check the current status of IP forwarding:

```
cat /proc/sys/net/ipv4/ip_forward
```

A value of 0 indicates that IP forwarding is disabled. To enable it, the value needs to be changed to 1 :

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

After executing this command, verifying the file content again should show 1 , confirming that port forwarding is enabled.

5. Executing ARP Poisoning

With port forwarding enabled, the next step is to perform ARP poisoning using a tool like arpspoof . This tool sends continuous, forged ARP replies to both the victim and the gateway, tricking them into updating their ARP tables with the attacker's MAC address.

First, to poison the victim's ARP table, making it believe the attacker is the gateway:

```
arpspoof -t 10.35.1.199 10.35.1.2
```

Here, `-t` specifies the target (victim's IP), and the second IP is the IP address the target should associate with the attacker's MAC (the gateway's IP).

Second, to poison the gateway's ARP table, making it believe the attacker is the victim:

```
arp spoof -t 10.35.1.2 10.35.1.199
```

In this command, the target is the default gateway, and the IP address it should associate with the attacker's MAC is the victim's IP. These two commands, run concurrently in separate terminals, establish the attacker's machine as the man-in-the-middle, forwarding traffic in both directions.

6. Network Sniffing Techniques

Sniffing is the act of monitoring and capturing data packets as they traverse a network. It's akin to tapping a wire to listen in on conversations. A key component of sniffing is setting the Network Interface Card (NIC) into "promiscuous mode." By default, an NIC only processes packets addressed to its own MAC address. In promiscuous mode, the NIC captures all traffic on the network segment, regardless of the destination MAC address. This is essential for a sniffer to see all data.

Sniffing can be categorized into two types:

- * **Passive Sniffing:** This involves simply listening to traffic without altering it. It was effective on older hub-based networks, where traffic was broadcast to all connected devices. However, modern networks primarily use switches, which intelligently direct traffic only to the intended recipient, making passive sniffing largely ineffective.
- * **Active Sniffing:** This technique is used in switch-based networks to overcome the limitations of passive sniffing. It involves actively injecting packets into the network to manipulate traffic flow. Examples include MAC flooding (overloading a switch's CAM table to force it into a broadcast mode), DHCP attacks, DNS poisoning, and the ARP poisoning technique demonstrated. Active sniffing allows the attacker to not only monitor but also potentially alter network traffic.

Sniffing can reveal sensitive information such as email traffic, FTP passwords, web traffic (especially unencrypted HTTP), Telnet passwords, router configurations, chat sessions, and DNS traffic.

7. Capturing Data with Wireshark

Once the ARP poisoning is active and the attacker is positioned as the man-in-the-middle, a sniffing tool like Wireshark can be used to capture and analyze the intercepted traffic.

1. **Launch Wireshark:** Open Wireshark on the attacker machine.
2. **Select Interface:** Choose the network interface (e.g., `eth0`) that is actively participating in the MITM attack.
3. **Start Capture:** Begin capturing packets.
4. **Generate Victim Traffic:** From the victim machine, perform an action that generates network traffic, such as logging into a web application (e.g., `aview.in`) with a username and password.
5. **Filter Traffic:** In Wireshark, apply filters to narrow down the captured packets. For instance, to view unencrypted web traffic, use the filter `http` .
6. **Analyze Packets:** Locate relevant HTTP POST requests, which often contain login credentials. Right-clicking on a packet and selecting "Follow TCP Stream" can reconstruct the entire conversation, revealing the username and password in plain text if the connection was not encrypted (e.g., using HTTPS).

For example, if a victim logs into a site with username "admin" and password "nptel1234" over HTTP, Wireshark can capture this data, displaying the credentials clearly within the TCP stream. This demonstrates how ARP poisoning combined with sniffing can effectively compromise sensitive information transmitted over an unencrypted network.

Key Takeaways

- [] ARP is a stateless protocol that maps IP addresses to MAC addresses, making it vulnerable to manipulation.
- [] ARP poisoning (or spoofing) involves sending forged ARP messages to redirect network traffic through an attacker's machine.
- [] Man-in-the-Middle (MITM) attacks leverage ARP poisoning to intercept, monitor, and potentially alter communications between two parties.
- [] Enabling IP forwarding on the attacker's machine is crucial for an MITM attack to ensure intercepted traffic reaches its intended destination.
- [] Tools like `arpspoof` are used to execute ARP poisoning by continuously sending forged ARP replies to both the victim and the gateway.
- [] Network sniffing involves capturing and analyzing network packets, often requiring the NIC to be in promiscuous mode.
- [] Active sniffing techniques, such as ARP poisoning, are necessary to intercept traffic in modern switch-based networks.
- [] Wireshark is a powerful tool for capturing and analyzing intercepted network traffic, allowing for the extraction of sensitive data like login credentials from unencrypted protocols.

- [] Protocols like SSL/TLS (HTTPS) encrypt data, providing a defense against sniffing and MITM attacks by making intercepted data unreadable.

Conclusion

The exploration of Man-in-the-Middle attacks, particularly through ARP poisoning and sniffing, highlights a significant vulnerability in network communications. By understanding how attackers can exploit the fundamental mechanisms of network protocols like ARP, we gain critical insights into the importance of robust security practices. The practical demonstration underscores that unencrypted traffic, even on a local network, is highly susceptible to interception and compromise.

This lesson serves as a stark reminder that while network infrastructure has evolved with switches replacing hubs, active attack techniques have also advanced to circumvent these improvements. For students and professionals alike, recognizing the mechanics of these attacks is the first step towards building more secure systems. Implementing end-to-end encryption (e.g., HTTPS for web traffic, VPNs for general network traffic) and employing network monitoring tools to detect suspicious ARP activity are essential countermeasures. As digital interactions become increasingly pervasive, a proactive and informed approach to network security is indispensable to protect sensitive information from malicious actors.